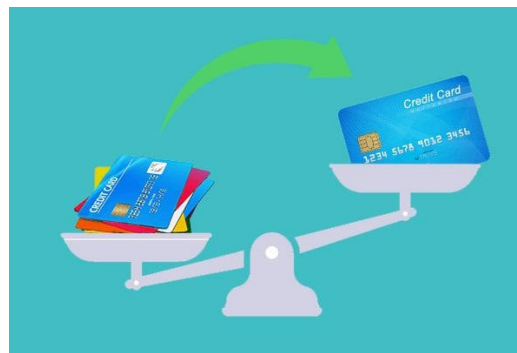


Secure Software Design and Development (CY-321)

Security Needs Elicitation



“What security questions should we ask this client before writing a single line of code?”

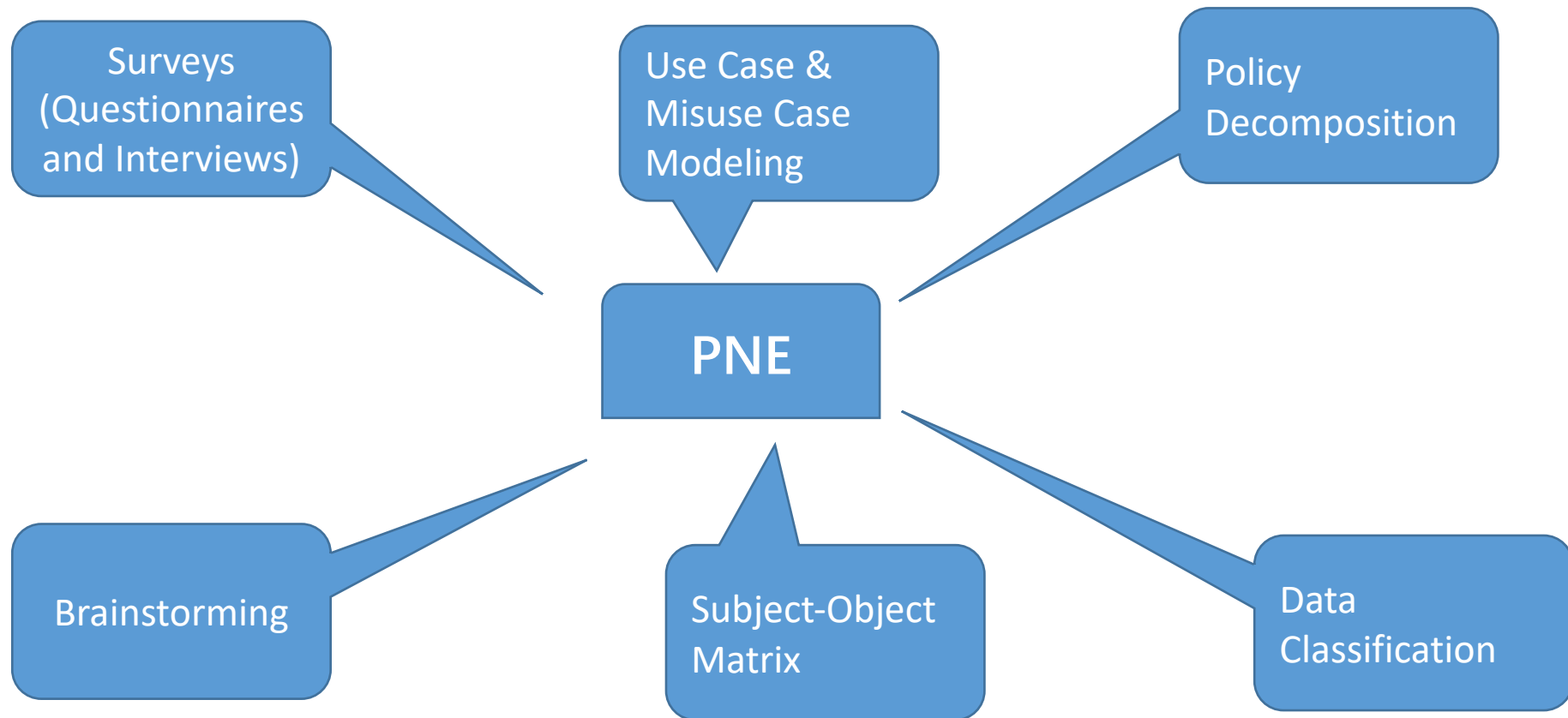
Security Requirements

Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

The process of discovering and documenting the security needs of a system by asking the **right questions** to the **right stakeholders**

Protection Needs Elicitation (PNE)

The Good question is How you gonna do it?



Protection Needs Elicitation (PNE)

Brainstorming



Quick-and-dirty way

- An exceptional method of eliciting a lot of innovative notions for a zone of curiosity

How many choices are obtainable to get an answer to the existing problem just around the corner?

- What aspects are compelling the group from moving forward with a method or choice?
- In what way can the problem be solved by a particular group?



Protection Needs Elicitation (PNE)

Brainstorming



Quick-and-dirty way

Shortcomings

- Brainstorming solutions are usually not comprehensive and consistent because it is very subjective
- High degree of likelihood that the brainstormed ideas don't directly relate to the business, technical and security context of the software

Protection Needs Elicitation (PNE)

Surveys (Questionnaires and Interviews)

The effectiveness of the survey is dependent on how applicable the questions in the surveys are to the **audience** that is being surveyed

“Which cryptographic algorithm do you prefer for protecting your financial transactions?”

The questionnaires are not a one size fits for all type of survey

“Should the system require two-factor authentication?”

Both **explicitly specified questions** as well as **open ended questions** should be part of the questionnaire

“What security concerns do you have about the system?”

Protection Needs Elicitation (PNE)

Policy Decomposition

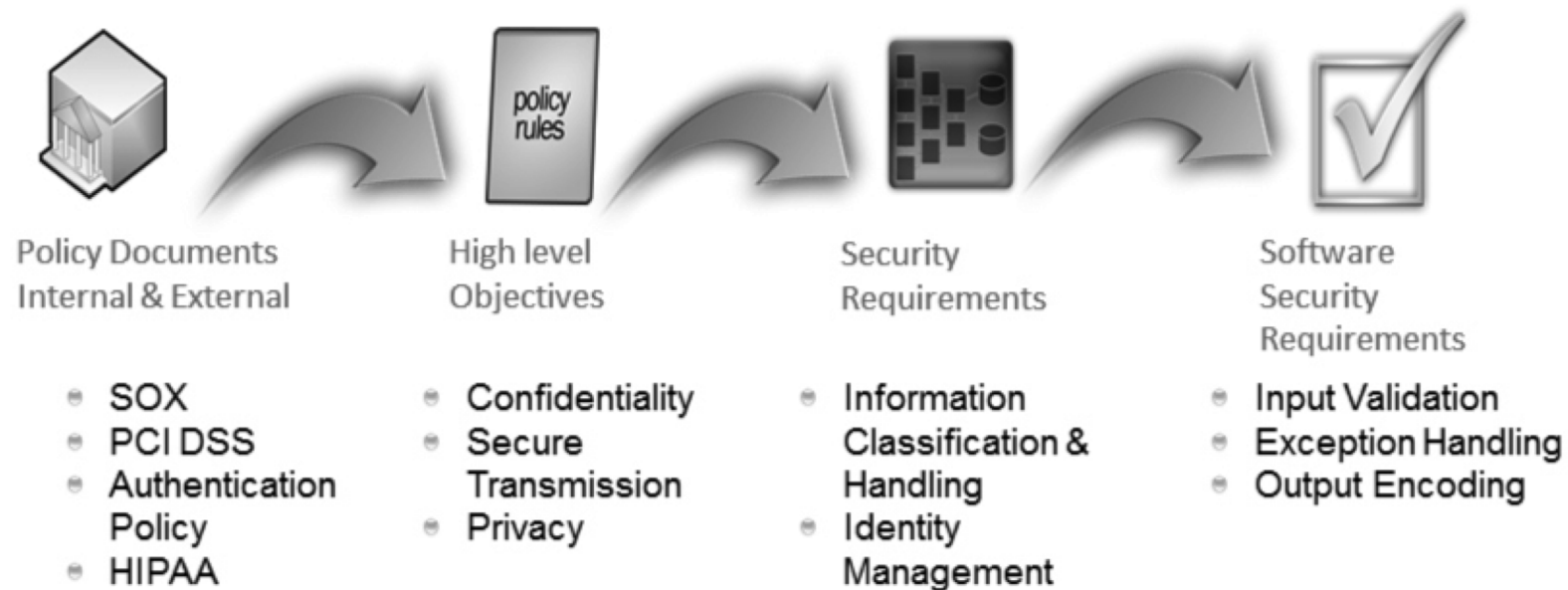
One of the sources for security requirements is internal organizational policies that the organization need to comply with

the decomposition process is objective and compliant with the security policy, and not merely someone's opinion

“I think users should change their passwords every 30 days because that's more secure.”

Protection Needs Elicitation (PNE)

Policy Decomposition

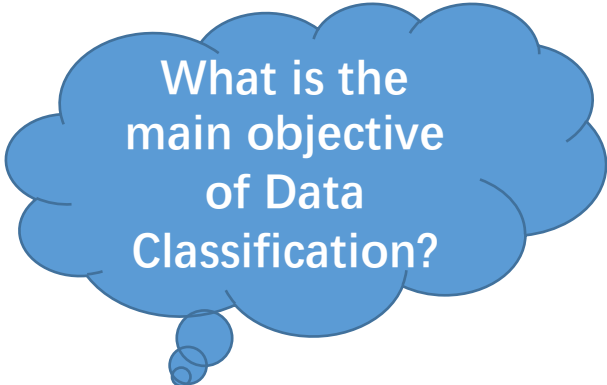


Protection Needs Elicitation (PNE)

Data Classification

Data classification is based on CIA

Data classification can also assist in increasing the quality of risk based decisions

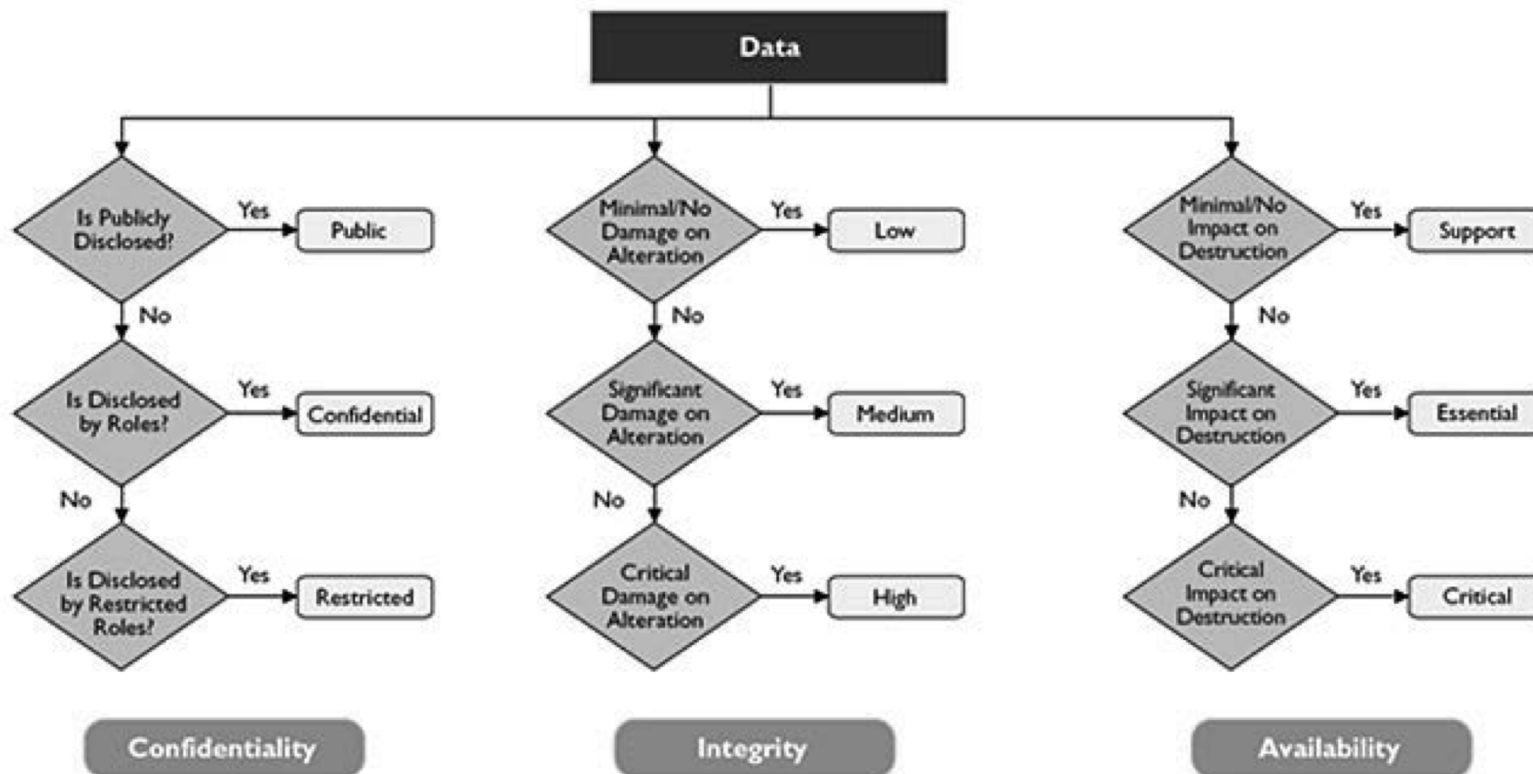


What is the
main objective
of Data
Classification?

The data quality and characteristics are known upon classification, decisions that are made to protect them can also be made appropriately.

Protection Needs Elicitation (PNE)

Data Classification



Protection Needs Elicitation (PNE)

Subject/Object Matrix

A subject-object matrix is a two-dimensional representation of roles and components

The subjects or roles are listed across the columns and the objects or components are listed down the rows

A subject-object matrix is a very effective tool to generate misuse cases

Who,
What,
What they are
allowed to
do?

Protection Needs Elicitation (PNE)

Use Case & Misuse Case Modeling

Use Cases

A use case models the intended behavior of the software or system

The sequence of actions and events that are to be taken to address a business need

Use case modeling is meant to model only the most significant system behavior

Use case modeling includes identifying actors, intended system behavior (use cases), and sequences and relationships between the actors and the use cases

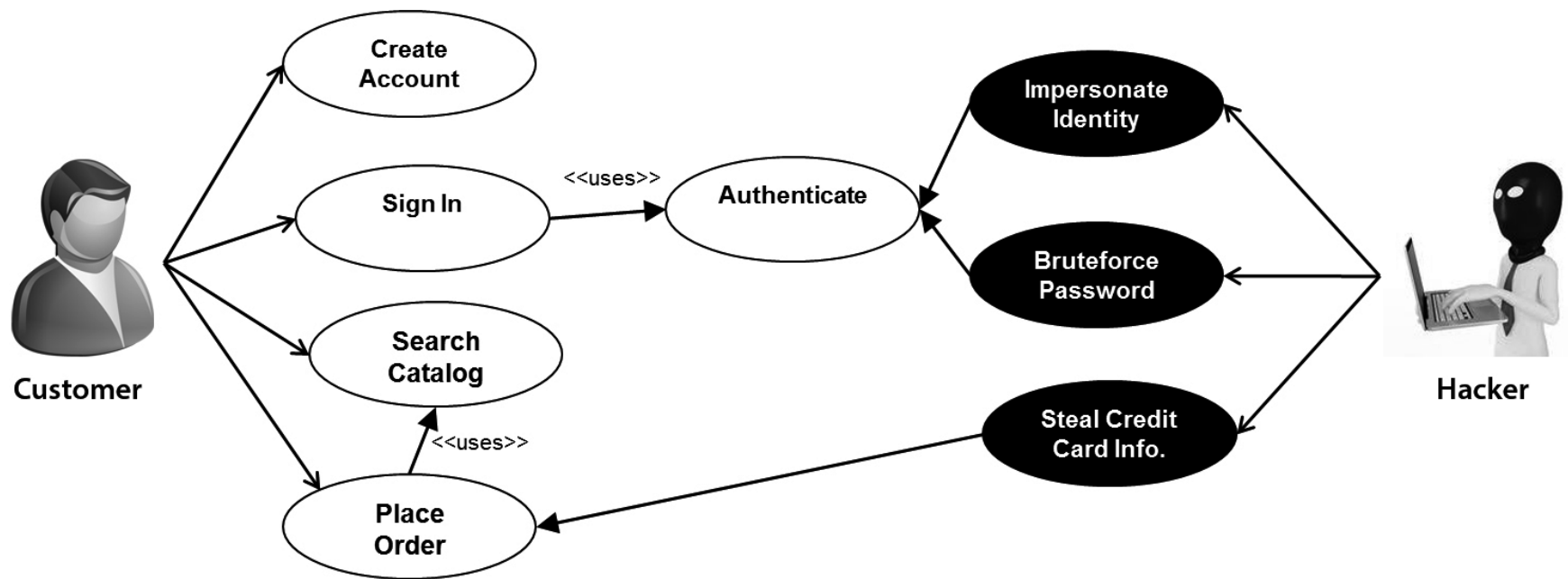
Misuse Cases

Misuse cases, also known as abuse cases help identify security requirements by modeling negative scenarios.

Misuse cases can be created through brainstorming negative scenarios like an attacker

Protection Needs Elicitation (PNE)

Use Case & Misuse Case Modeling



Semester Project

- **Student Information (All Team members names and reg#)**
- **Project Title**
- **Summary of the Project**
- **Specific Security Problem Addressed**
- **Impact of the Proposed Solution**

One Page

Email me, keeping Hadia in CC

Questions??

zubair.ahmad@giki.edu.pk

Office: G14 FCSE lobby